



Cybersecurity Review Pack

Technologies, third-party components, controls, risks, and a full inventory of every interactive control.

Prepared for	TAQA Cybersecurity
Prepared by	Mohammed Al-Jahdali
Assessed	main @ 01e7cd5, 4 Aug 2026
Platform	TAQA Knowledge Hub

INTERNAL USE

Contents

1. The single most important fact	3
2. Technology inventory	3
3. Third-party components and services	5
4. Data handling	5
5. Security controls in place	7
6. Interactive control inventory	7
7. Open risks	11
8. What we are asking Cybersecurity for	13
9. Summary	13

1. The single most important fact

The application makes no network calls of any kind.

A search across all 33 files for `fetch()` , `XMLHttpRequest` , `WebSocket` , `navigator.sendBeacon` and HTML form `action` attributes returns nothing. There is no code path that transmits data anywhere.

The only network activity is the service worker retrieving the site's own files from its own origin so that pages work offline.

This was confirmed a second way. All ten pages were loaded in an instrumented browser with every network request recorded, and no request reached any host other than the site's own origin.

Everything in section 6 follows from this. No button in this application sends data anywhere, because there is nowhere for it to send data to.

2. Technology inventory

What the application is built from

Component	Version or detail	Purpose	Source
HTML, CSS, JavaScript	No framework	The entire application	Written in house
<code>qrcode.js</code>	1.4.4, MIT licence	Generates QR codes inside the browser	Kazuhiko Arase, vendored into the repository
Urbanist typeface	Latin subset, woff2	Body and heading text	SIL Open Font License, self-hosted
Inter typeface	Latin subset, woff2	Body text	SIL Open Font License, self-hosted
Bw Gradual	OTF	TAQA corporate typeface	TAQA brand assets, self-hosted

There is no `package.json` , no `node_modules` and no package manager. The application has no dependency tree, so there is no transitive dependency risk and nothing to patch for CVEs.

Platform and hosting

Layer	What is used	Notes
Source control	GitHub	Currently a personal repository, to be transferred to TAQA
CI/CD	GitHub Actions	Automatic deploy on merge to <code>main</code>
Hosting today	GitHub Pages	Free tier, public
Hosting intended	Azure Static Web Apps	Currently offline, see section 5
Runtime	The visitor's browser	No server-side execution of any kind

Browser APIs used

These are the only browser capabilities the application touches. None of them requires a permission prompt, and none accesses the camera, microphone, location or contacts.

API	Where it is used	What it does
<code>localStorage</code>	Throughout	Stores preferences on the visitor's own device. Contents listed in section 4
<code>sessionStorage</code>	<code>fixes.js</code>	Reads a key named <code>taqa_user</code> if present. This is a placeholder for the future Entra ID integration and nothing currently writes to it
Service Worker	<code>service-worker.js</code>	Caches the site's own pages so they open offline
<code>navigator.clipboard</code>	Segment and QR views	Copies a page link when the user clicks Copy
<code>navigator.onLine</code>	Shared script	Shows an offline banner when the connection drops
<code>window.print</code>	Document viewer	Opens the browser's own print dialog
File input	Upload and support pages	Lets the user select a file. The file is never read, stored or transmitted

The application does not use cookies, IndexedDB, WebRTC, geolocation, camera access, push notifications or Web Bluetooth.

3. Third-party components and services

External services: none

The application previously called four external services. All were removed on 3 August 2026 and the removal was verified by network recording.

Service that was removed	What it received	Removed on	Replaced by
Google Apps Script endpoint	Names and work email addresses submitted through a sign-up form	3 August 2026	The form is deleted. Entra ID sign-in will provide identity
Google Analytics and Tag Manager	Page view telemetry	3 August 2026	Nothing. A TAQA-approved analytics tool is to be selected
<code>api.qrserver.com</code>	Document URLs, sent to generate QR images	3 August 2026	QR codes are generated inside the browser using the vendored MIT library
Google Fonts CDN	An asset request on every page load	3 August 2026	Fonts are self-hosted at 398 KB

The Google Apps Script endpoint is worth flagging explicitly. Between the platform going live and 3 August 2026, any user who completed the sign-up form had their name and work email address transmitted to a Google-hosted endpoint outside the TAQA tenant. This may have implications under PDPL for cross-border transfer of personal data, and Cybersecurity should decide whether it needs to go any further. The code path is now removed.

Third-party code in the repository

One file: `qrcode.js`, MIT licensed, roughly 2,300 lines, added specifically so that QR generation no longer required calling an outside service. It performs mathematical encoding only, and contains no network code.

Supply chain position

With no package manager and one vendored library, the supply chain surface is close to zero. This is the strongest part of the platform's security posture and it is a deliberate design choice rather than an accident.

4. Data handling

What data the application holds

Nothing on any server, because there is no server. Everything below lives in the individual visitor's own browser and never leaves their device.

Storage key	Contents	Sensitivity
<code>taqa-theme</code>	Light or dark preference	None
<code>taqa-bookmarks</code>	Titles of bookmarked documents	Low
<code>taqa-recent</code>	Recently viewed document titles	Low
<code>taqa-read-docs</code>	Which documents have been opened	Low
<code>taqa-analytics</code>	A local counter of page views	Low
<code>taqa-doc-hashes</code>	File fingerprints used for duplicate detection on the upload page	Low
<code>taqa-tour-done</code>	Whether the introductory tour has been dismissed	None
<code>taqa-bell-count</code>	A notification badge number	None
<code>taqa-last-sync</code>	A timestamp	None

No credentials, no personal data, no document content and no session tokens are stored. Clearing the browser cache removes all of it, and nothing is shared between users or devices.

What data the application does not have

There are no real documents in the platform. Document titles are reference metadata held in JavaScript files, and the viewer displays a placeholder rather than an actual file. No operational TAQA document has been loaded into the system.

5. Security controls in place

Control	Status	Evidence
Content-Security-Policy	In place	Enforced on every page, restricted to <code>'self'</code> . Any attempt to contact a third party is blocked by the browser itself rather than merely being absent from the source
Transport security	In place	HTTPS only. <code>Strict-Transport-Security</code> , <code>X-Content-Type-Options: nosniff</code> , <code>X-Frame-Options: SAMEORIGIN</code> and <code>Referrer-Policy</code> are configured in <code>staticwebapp.config.json</code> for the Azure deployment
Output encoding	In place	All user-controlled values are HTML-escaped before display. Added 3 August 2026 after a confirmed cross-site scripting finding, covered in section 7
File type restriction	In place	A code-level allow-list, not the HTML <code>accept</code> attribute. <code>.exe</code> and <code>.msi</code> are refused, including double extensions such as <code>trick.pdf.exe</code> . Verified through the drag-and-drop bypass path
Secret management	In place for current scope	No secrets exist in the platform. Every commit in the repository history was scanned and no hardcoded credentials were found. Deployment tokens are held in GitHub's encrypted secret store and referenced by name only
Dependency management	In place	No package manager and no dependency tree
Change traceability	In place	Every change is a commit and every deployment is a logged GitHub Actions run tied to that commit
Authentication	Not in place	No login exists. Requires the Azure App Registration
Authorisation	Not in place	No roles or permissions exist. Requires authentication first
Server-side logging	Not possible yet	There is no server to log on
Malware scanning	Not possible yet	No file is stored or transmitted, so there is nothing to scan
Branch protection	Not in place	<code>main</code> is unprotected. The GitHub API reports <code>"protected": false</code> . Requires a nominated technical reviewer

6. Interactive control inventory

Every interactive element in the application, and what happens when it is used.

The three columns that matter for review are the last three. **Network** is whether the control sends data anywhere. **Storage** is whether it writes to the browser's local storage. **Data** is whether it touches anything sensitive.

Across all 126 buttons and 151 click handlers in the application, the Network column reads "None" without exception.

Controls that appear on every page

Control	What happens when clicked	Network	Storage	Data
Dark mode toggle	Switches the colour theme	None	Writes <code>taqa-theme</code>	None
Navigation links	Moves to another page in the same site	None	None	None
Back to top	Scrolls the page upward	None	None	None
Notification bell	Scrolls to a list already on the page	None	None	None
Search box in the header	Filters items already loaded in the browser	None	None	None

Home page

Control	What happens when clicked	Network	Storage	Data
Segment cards, 12 of them	Opens that segment's page	None	None	None
Search button	Filters the list held in the browser. No query is sent anywhere	None	None	Search text stays in the page
Accordion sections	Expands or collapses a panel	None	None	None
Guided tour, Next and Skip	Advances or dismisses a five-step introduction	None	Writes <code>taqa-tour-done</code>	None

Segment page

Control	What happens when clicked	Network	Storage	Data
Document card	Opens a preview panel showing the document's title and type	None	Writes <code>taqa-recent</code> and <code>taqa-read-docs</code>	Title only
Bookmark star	Adds or removes the title from a local list	None	Writes <code>taqa-bookmarks</code>	Title only
QR code button	Generates a QR image inside the browser encoding the page link	None	None	The page URL
Copy link	Copies the current page address to the clipboard	None	None	The page URL
Sort controls	Reorders the list already displayed	None	None	None
Pagination	Shows a different slice of the same list	None	None	None

Document viewer

Control	What happens when clicked	Network	Storage	Data
Request Access	Displays an on-screen message. No request is sent to anyone	None	None	None
Bookmark	Adds or removes the title from a local list	None	Writes <code>taqa-bookmarks</code>	Title only
Print	Opens the browser's own print dialog	None	None	None
Pin, Quick Reference, Revision History, Sunlight mode	Show, hide or restyle panels already on the page	None	None	None

Upload page

Control	What happens when clicked	Network	Storage	Data
Browse Files, or drag and drop	Opens the file picker and lists the chosen filenames on screen. The file contents are never read, stored or transmitted	None	None	Filename displayed only
A file with a blocked extension	Refused, with an on-screen message naming the permitted types. <code>.exe</code> and <code>.msi</code> are rejected including double extensions	None	None	None
Remove file	Removes an entry from the on-screen list	None	None	None
Submit	Shows a confirmation with a randomly generated reference number. Nothing is uploaded, stored or sent. The page is an interface awaiting the SharePoint integration	None	None	None

Support ticket page

Control	What happens when clicked	Network	Storage	Data
Attach photo	Opens the file picker for images. The image is displayed in the page and never leaves the browser. No camera permission is requested	None	None	Image held in page memory only
Annotation tools: rectangle, circle, arrow, freehand, colour, width, undo, clear	Draw on the attached image inside the browser	None	None	None
Priority selection	Highlights the chosen priority	None	None	None
Submit	Shows a confirmation with a randomly generated ticket number. No ticket is created and nothing is sent. The page awaits the Power Automate integration	None	None	None

Dashboard

Control	What happens when clicked	Network	Storage	Data
Approve or Reject a document	Updates the on-screen list only. No approval is recorded anywhere and nothing is sent	None	None	None
Add Contributor	Adds a name to the on-screen list for the current session only. Lost on refresh	None	None	Name displayed only

Analytics page

Control	What happens when clicked	Network	Storage	Data
Export CSV	Builds a file in the browser from the local counters and saves it to the user's own device. Nothing is transmitted	None	Reads <code>taqa-analytics</code>	Local counters only
Clear analytics	Deletes the local counters	None	Clears <code>taqa-analytics</code>	None

Glossary and search pages

Control	What happens when clicked	Network	Storage	Data
Search, filter, alphabet and category controls	Filter a list already held in the browser	None	None	None
Submit a term	Displays a confirmation. Nothing is saved or sent	None	None	None
Ask a question, on the search page	Matches the typed text against a fixed local list and shows results. There is no AI service behind this and no query leaves the browser	None	None	Query stays in the page

A note on the AI-labelled pages

The pages named "AI Document Search" and "Ask Expert" contain no artificial intelligence and no connection to any language model. They perform keyword matching against a fixed list held in a JavaScript file. No text typed into them is transmitted anywhere.

If an actual AI service is connected in future, that will be a material change requiring its own security review, covering where prompts are sent, whether document content leaves the tenant, retention, and whether data is used for training.

7. Open risks

Rated for the platform as it exists today, and again for after the SharePoint integration, because several change severity sharply once real documents are stored.

#	Risk	Today	After integration	Status and treatment
R-01	No authentication. The site is open to anyone with the URL	Medium	Critical	Open. Closed by Entra ID sign-in. Until then the platform must not hold real operational documents. This is the reason none have been loaded
R-02	The repository is public. All code and document titles are readable on the internet	Low	Medium	Open, deliberate and time-boxed. GitHub requires a public repository for the free preview link. To be made private once TAQA hosting is live. No credentials or real documents are exposed
R-03	Progressive Web App offline caching. The application installs on phones and caches pages for offline reading. Once real documents are added, TAQA content will be cached on whatever device installed it, including personal devices outside MDM control	Low	High	Open, needs a decision. No policy exists yet on whether offline caching of operational documents on personal devices is acceptable. Recommend deciding this before Phase 2
R-04	<code>.zip</code> archives are accepted for upload and their contents cannot be inspected in the browser. An executable can be placed inside an archive	Low	Medium	Open and accepted. To be mitigated by server-side antivirus through Defender for Storage or SharePoint at Phase 3. Recorded for the exception register
R-05	<code>script-src</code> permits <code>'unsafe-inline'</code> , which weakens the Content-Security-Policy's ability to contain script injection	Medium	Medium	Open and deferred. Removing it requires relocating every inline script across roughly 13,000 lines. Recommend doing this during the Azure migration rather than as an isolated change
R-06	No branch protection. Changes can reach the live site without review	Medium	High	Open. Requires D&T to nominate a technical reviewer. Protection can be enabled immediately
R-07	Segregation of duties. One person is currently developer, approver and platform owner	Medium	High	Open. Resolved by the technical reviewer and the assigned IT coordinator
R-08	Historical personal data transfer. The removed sign-up form transmitted names and work email addresses to a Google-hosted endpoint outside the TAQA tenant	Medium	n/a	Code path removed 3 August 2026. Cybersecurity to decide whether any PDPL notification obligation arises
R-09	The platform was built outside IT governance, on a personal GitHub account and a personal Azure trial subscription	Medium	High	Being resolved. The handover to D&T transfers the repository, the hosting and the ownership
R-10	No server-side audit trail of who accessed which document	Low	High	Not yet possible, as there is no server. Arrives with SharePoint and Azure logging

Findings already closed

Finding	Severity	Closed
Cross-site scripting through a filename on the upload page. A file named <code>.pdf</code> executed script. Confirmed by test rather than inspection	Low today, high after integration	3 August 2026. All user-controlled values are escaped. Re-tested with the same payload, which now renders as inert text
Executable file types accepted for upload	Low today, high after integration	3 August 2026. Code-level allow-list, verified through the bypass path
A function-name collision was silently suppressing upload warnings, so a refused file would have failed with no message to the user	Medium	3 August 2026
Four external service dependencies	Medium	3 August 2026. Verified by network recording

8. What we are asking Cybersecurity for

1. Confirmation of which framework this platform is assessed against. The Kosli Secure SDLC template has been used for the delivery process, and an OWASP-style application review was run alongside it. We would like to know whether NCA ECC, NCA CCC or any Aramco third-party requirement applies.
2. A decision on R-03, offline caching of operational documents on personal devices. This needs answering before real documents are loaded.
3. A view on R-08, whether the historical personal data transfer requires any notification.
4. Agreement that penetration testing and dynamic scanning are scheduled after Entra ID and SharePoint are in place. Testing the current platform would examine a static file server rather than the system that will go live.
5. A named security contact for the integration phases.

9. Summary

The application is a front end with no server, no backend, no database and no network calls. Every button either changes what is displayed on screen or writes a preference to the visitor's own browser. Nothing transmits data, because there is no code path capable of doing so.

There are no third-party services. All four that previously existed were removed and the removal was verified. One MIT-licensed library is vendored into the repository, and there is no package manager and no dependency tree.

Four findings were identified and closed during this review, including a confirmed cross-site scripting vulnerability. Ten risks remain open. Six of those close through the Azure and Entra ID integration, three need a decision from Cybersecurity or D&T, and one is a repository setting that can be changed today.

The controls that are missing are missing because the platform has no identity provider, no server and no stored data. They become implementable at integration, not before, and this assessment should be repeated once that work is complete.

Mohammed Al-Jahdali. mohammed.jahdali@tq.com. +966 54 773 3744
